AUTHORIZED SECURITY LAB DOSSIER

Legal Scope, Asset Inventory & Threat Model

Prepared by:

S Tejo Lakshman

Lab Owner:

RabTech Lab

Assessment Type:

Authorized Security Testing

Environment:

Isolated Cybersecurity Training Laboratory

Approval Date:

18 September 2026

1. EXECUTIVE SUMMARY

This document defines the authorized scope, asset inventory, trust boundaries, threat model, rules of engagement, evidence-handling procedures, and stopping conditions for a controlled cybersecurity assessment.

The assessment is restricted to two intentionally designated laboratory assets: a local training web application and a deliberately vulnerable virtual machine. Both systems are intended for security training and validation.

Testing will be performed only against systems explicitly included in the approved asset inventory. Public internet systems, third-party infrastructure, production systems, and unauthorized assets are outside the scope of this assessment.

The assessment follows a controlled and non-destructive methodology. Denial-of-service activities, persistence, destructive payloads, uncontrolled data extraction, and outbound attacks are prohibited.

The objective is to identify security weaknesses safely, document evidence, evaluate threats using the STRIDE methodology, and provide appropriate security mitigations.

2. WRITTEN AUTHORIZATION

Lab Owner: RabTech Lab

Assessor: S Tejo Lakshman

Assessment Type: Authorized security testing of an isolated cybersecurity training environment.

Approval Date: 18 September 2026

Approved Assets:

LAB-01 — Local Training Web App

URL: http://127.0.0.1:8080

LAB-02 — Deliberately Vulnerable VM

IP Address: 192.168.56.20

Authorization Statement:

RabTech Lab authorizes the assessor to perform controlled security testing against the assets explicitly listed in this document. Testing must remain within the defined environment and approved testing window.

Any system, address, account, service, or resource that is not explicitly listed in the approved asset inventory is considered out of scope and must not be tested.

3. SCOPE AND BOUNDARIES

3.1 IN-SCOPE ASSETS

The following systems are authorized for testing:

- LAB-01 — Local Training Web App
- LAB-02 — Deliberately Vulnerable VM

3.2 OUT-OF-SCOPE ASSETS

The following are explicitly excluded:

- Public internet systems
- Third-party systems
- Production systems
- Cloud infrastructure not explicitly authorized
- Other virtual machines
- Personal devices
- Systems not listed in the asset inventory
- External IP addresses
- Unrelated websites and services

4. ASSET INVENTORY

Asset ID	Asset Name	Owner	Environment	IP/URL	Testing	Excluded Actions	Window	Evidence
LAB-01	Local Training Web App	RabTech Lab	Isolated localhost	http://127.0.0.1:8080	Yes	No DoS / third-party scanning	Approved window	Confidential
LAB-02	Deliberately Vulnerable VM	RabTech Lab	Private host-only network	http://192.168.56.20	yes	No persistence / outbound traffic	Approved window	Confidential

5. ASSET CLASSIFICATION

Asset	Confidentiality	Integrity	Availability	Overall Risk
LAB-01	Medium	High	Medium	High
LAB-02	Medium	High	Medium	High

Confidentiality:

Test data and credentials must not be exposed outside the laboratory.

Integrity:

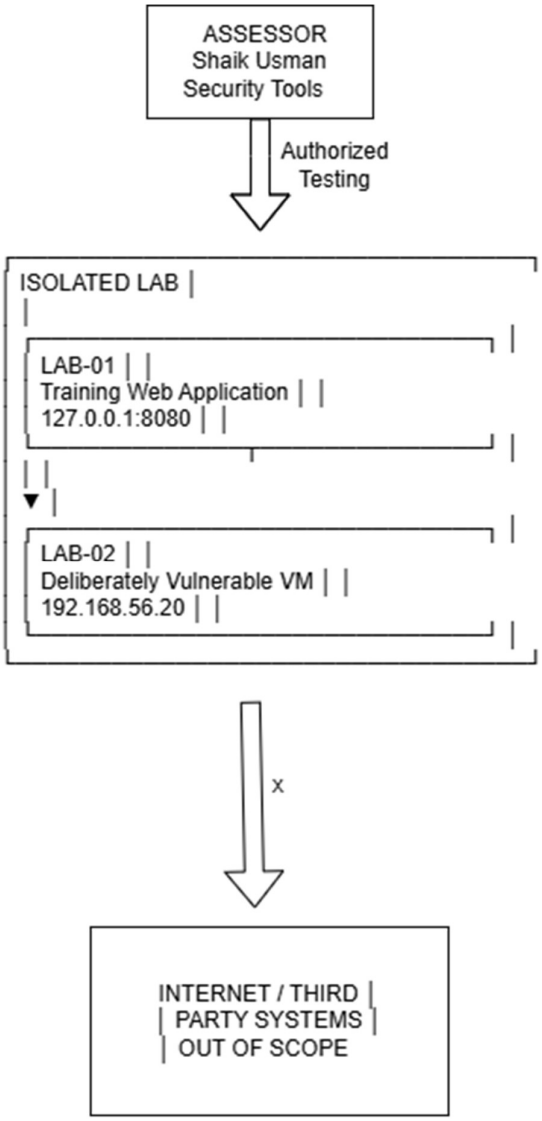
Unauthorized modification of laboratory systems could affect the validity of testing.

Availability:

Testing must not intentionally make laboratory services unavailable.

6. TRUST BOUNDARY DIAGRAM

The following diagram identifies the boundary between the authorized assessment environment and systems that are explicitly out of scope.



7. DATA CLASSIFICATION

Data	Classification	Handling
Application test data	Confidential	Store locally
Vulnerability screenshots	Confidential	Redact secrets
Logs	Confidential	Restrict access
Credentials	Sensitive	Do not publish
Personal information	Sensitive	Minimize/redact
Final report	Confidential	Authorized reviewers only

8. STRIDE THREAT MODEL

ID	STRIDE Category	Asset	Threat	Risk
T-01	Spoofing	LAB-01	User impersonation	High
T-02	Tampering	LAB-01	Unauthorized data modification	High
T-03	Repudiation	LAB-01/LAB-02	Actions cannot be reliably attributed	Medium
T-04	Information Disclosure	LAB-01	Sensitive information exposure	High
T-05	Denial of Service	LAB-01/LAB-02	Service availability impact	High
T-06	Elevation of Privilege	LAB-02	Low privilege → higher privilege	Critical

T-01 — Spoofing

An attacker may attempt to impersonate a legitimate user.

Potential Impact:

Unauthorized account access and access to restricted resources.

Mitigation:

Strong authentication, secure session management and rate limiting.

T-02 — Tampering

An attacker may attempt to modify application or system data without authorization.

Potential Impact:

Data corruption and loss of integrity.

Mitigation:

Server-side validation, authorization checks and appropriate file permissions.

T-03 — Repudiation

A user may deny performing an action when sufficient audit information is unavailable.

Mitigation:

Timestamped security logs, session identifiers and protected audit records.

T-04 — Information Disclosure

Sensitive information may be exposed through application responses, error messages, configuration information or unauthorized access.

Mitigation:

Access control, secure error handling, secret management and data minimization.

T-05 — Denial of Service

Excessive requests could affect the availability of laboratory services.

DoS testing is explicitly excluded from this assessment.

Mitigation:

Rate limiting, request throttling and resource monitoring.

T-06 — Elevation of Privilege

A low-privileged user may attempt to obtain higher privileges.

Potential Impact:

Unauthorized administrative access.

Mitigation:

Least privilege, role-based access control and server-side authorization.

9. ABUSE CASES

Attacker

↓

Authentication Attempt

↓

Login System

↓

Weak Authentication

↓

Unauthorized Access

Mitigation: Strong authentication and rate limiting.

Abuse Case 2 — Unauthorized Data Access

Low-Privilege User

↓

Restricted Resource

↓

Authorization Check

↓

Missing Authorization

↓

Data Exposure

Mitigation: Server-side authorization checks.

Abuse Case 3 — Privilege Escalation

Normal User

↓

Privileged Action

↓

Authorization Check

↓

Improper Validation

↓

Higher Privileges

Mitigation: Least privilege and role-based access control.

10. RULES OF ENGAGEMENT

10.1 PERMITTED TECHNIQUES

The following activities are permitted against LAB-01 and LAB-02:

- Service enumeration
- Port identification
- Web application security testing
- Authentication testing
- Authorization testing
- Input validation testing
- Vulnerability identification
- Safe proof-of-concept validation
- Screenshot and log collection

• Security reporting

10.2 EXPLICIT EXCLUSIONS

The following activities are prohibited:

• Denial-of-service attacks

• Destructive payloads

• Malware deployment

• Persistence

• Third-party scanning

• Public internet scanning

• Credential reuse outside the laboratory

• Social engineering

• Uncontrolled data extraction

• Testing unauthorized systems

11. TESTING WINDOW AND STOP CONDITIONS

Testing is permitted only during the approved assessment window.

Testing must immediately stop if:

1. A system outside the approved inventory is identified.

2. Testing affects a non-laboratory system.

3. The target becomes unstable.

4. Unexpected personal or sensitive information is discovered.

5. A destructive condition is encountered.

6. Unexpected outbound traffic occurs.

7. Authorization is withdrawn.

8. A service becomes unavailable because of testing.

Emergency Action:

The assessor must immediately stop testing, preserve only the minimum necessary evidence, document the event, and notify the lab owner or responsible reviewer.

12. EVIDENCE HANDLING

Only the minimum evidence necessary to demonstrate a security finding will be collected.

Evidence may include:

- Screenshots
- Sanitized HTTP requests/responses
- Application logs
- Service information
- Test timestamps
- Reproduction steps
- Sanitized command output

Evidence must be stored securely and should not contain unnecessary personal information, passwords, authentication tokens, or secrets.

Any sensitive information discovered during testing must be redacted before inclusion in the final report.

Evidence Classification:

CONFIDENTIAL — TRAINING EVIDENCE

13. SECURITY FINDING REPORTING

Each identified finding will contain:

- Finding ID
- Affected asset
- Vulnerability description
- Severity
- Security impact
- Reproduction steps
- Supporting evidence
- Risk rationale
- Recommended remediation
- Retest status

14. CONCLUSION

This security assessment has been designed as a controlled and authorized laboratory exercise.

The assessment scope is limited to LAB-01 and LAB-02. The defined trust boundaries, data flows, STRIDE threat model, abuse cases, rules of engagement, evidence-handling procedures and stopping conditions establish a controlled framework for security testing.

All testing must remain non-destructive and restricted to the authorized laboratory environment.

No public, production, third-party or otherwise unauthorized systems are included in the assessment.